
CloudSec LLM Triage Bot

Idea Principal del Proyecto

CloudSec LLM Triage Bot es una solución serverless orientada a mejorar el triage de hallazgos de seguridad en AWS. El proyecto recibe findings generados por Amazon GuardDuty y Amazon Inspector, los procesa mediante una AWS Lambda y utiliza un Large Language Model para enriquecer el análisis técnico con una interpretación estructurada del riesgo, contexto e indicadores relevantes.

La propuesta del proyecto no consiste en delegar decisiones críticas al modelo. El LLM actúa como analista asistente: resume, clasifica y recomienda. La decisión final siempre pasa por un policy engine determinístico que aplica reglas de seguridad explícitas y bloquea acciones peligrosas, especialmente cualquier intento de supresión automática sobre findings de alto riesgo, entornos productivos o patrones asociados con compromiso real.

El resultado final del proceso se distribuye a dos canales operativos clave. Por un lado, se envía un resumen accionable a Slack para notificación rápida al equipo de seguridad. Por otro, se crea una página en Confluence con la trazabilidad completa del caso: resumen ejecutivo, detalle técnico, análisis del LLM, decisión final de política, recomendación de remediación y finding crudo.

En términos de valor, el proyecto busca reducir tiempo de análisis, mejorar consistencia en la evaluación de findings y fortalecer la documentación operativa, sin comprometer principios de seguridad como least privilege, segregación de responsabilidades y control humano sobre decisiones sensibles.

Alcance del Proyecto

El alcance del proyecto cubre un flujo funcional de punta a punta dentro de AWS, desde la recepción de findings hasta la generación de notificaciones y documentación. En su estado actual, el proyecto incluye:

- Integración con Amazon GuardDuty y Amazon Inspector como fuentes de findings.
- Recepción de eventos mediante Amazon EventBridge.
- Procesamiento centralizado con AWS Lambda en una arquitectura

serverless.

- Soporte para analisis con LLM configurable, usando OpenAI o Amazon Bedrock.
- Validacion estructurada de la salida del LLM mediante modelos Pydantic.
- Aplicacion de reglas deterministicas de seguridad a traves de un policy engine.
- Envio de notificaciones operativas a Slack.
- Creacion automatica de documentacion en Confluence mediante REST API.
- Gestion de secretos con AWS Secrets Manager.
- Infraestructura reproducible con Terraform.
- Casos de prueba, documentacion, diagrama de arquitectura y guia de demo.

El proyecto esta disenado como un MVP academico y tecnico, por lo que tambien define limites explicitos. Quedan fuera de alcance:

- La supresion automatica real de findings en GuardDuty o Inspector.
- La ejecucion de acciones de contencion o remediacion automatica.
- La correlacion avanzada con CMDB, inventario empresarial o plataformas SIEM.
- Integraciones de ticketing como Jira o ServiceNow dentro del flujo principal.
- Alta disponibilidad avanzada del egress, ya que el MVP usa un unico NAT Gateway por razones de costo.

En resumen, el alcance del proyecto se centra en demostrar una integracion real entre servicios cloud, un LLM y herramientas de colaboracion empresarial, con una postura segura y trazable. La solucion esta pensada para mostrar viabilidad operativa, buenas practicas de diseno y una separacion clara entre recomendacion inteligente y decision de seguridad controlada.